NAN MUDHALVAN PROJECT

DOCUMENTATION

REPLACE AND MODERNIZE LEGACY VPN ARCHITECTURES WITH A CLOUD-NATIVE ZSCALER ZERO TRUST SOLUTION

TO REDUCE ATTACK SURFACE AND LATERAL MOVEMENT

TEAMMATES DETAILS

TEAM NO : 6

TEAM ID : 69a67acbf713ea4f3da534ce

TEAM LEADER : Valtina A

COLLEGE NAME : Rathinam College of Liberal Arts & Science @ Tips Global

COLLEGE CODE : CD

LIST OF TEAMMATES

S.NO	NAME	CONTACT EMAIL
1.	*AGNEESHWAR A*	aanbuagneesh@gmail.com
2.	*PRATHEESH M*	pratheeshmnp306@gmail.com
3.	*NITHIESH M*	nithieshm77@gamil.com
4.	*RAVIVARMA S*	maniravi0623@gmail.com
5.	*VALTINA A*	valtisusan07@gmail.com

ABSTRACT

Traditional Virtual Private Network (VPN) architectures have been widely used to provide secure remote access to organizational networks. However, legacy VPN solutions are increasingly vulnerable in modern IT environments due to the expansion of cloud services, remote workforces, and sophisticated cyber threats. These traditional systems often grant broad network access once a user is authenticated, which increases the attack surface and allows attackers to move laterally across systems if a single endpoint is compromised.

To address these security challenges, organizations are shifting toward the **Zero Trust security model**, which operates on the principle of "Never Trust, Always Verify." This approach eliminates implicit trust within the network and enforces strict identity verification, device validation, and least-privileged access controls before granting access to applications or resources.

This project focuses on replacing and modernizing legacy VPN architectures using a **cloud-native Zscaler Zero Trust solution**. The Zscaler platform provides secure, direct connectivity between users and applications through a cloud-delivered security architecture without exposing the internal network. By eliminating traditional network-level access, the system significantly reduces the attack surface and prevents unauthorized lateral movement within enterprise environments.

The proposed solution improves overall cybersecurity posture by enhancing visibility, simplifying security management, and enabling scalable, secure access for distributed users and cloud applications. Implementing Zscaler's Zero Trust framework allows organizations to move beyond outdated VPN models and adopt a modern, secure, and efficient access architecture suited for today's digital and cloud-driven infrastructure.

Keywords:

Zero Trust Security, Legacy VPN Architecture, Zscaler Zero Trust Exchange, Cloud-Native Security, Cybersecurity, Secure Remote Access, Attack Surface Reduction, Lateral Movement Prevention, Identity-Based Access Control, Cloud Security Architecture.

USE CASE SCENARIOS

1. SECURE REMOTE EMPLOYEE ACCESS

Scenario:

In traditional VPN architectures, remote employees connect to the corporate network through a VPN gateway and receive broad access to internal resources. This increases security risks if a user device is compromised. In the Zscaler Zero Trust model, remote employees access enterprise applications directly through the Zscaler cloud platform. Access is granted only after verifying user identity, device security posture, and organizational policies.

Output:

Employees securely access only authorized applications without exposing the internal network. This reduces the attack surface and eliminates unnecessary network-level access.

2. PREVENTING LATERAL MOVEMENT DURING A CYBERATTACK

Scenario:

In legacy VPN environments, if an attacker compromises a user's credentials, they may move laterally across the network to access sensitive systems. With Zscaler Zero Trust, users are connected directly to specific applications rather than the entire network. Each access request is verified continuously.

Output:

Even if credentials are compromised, attackers cannot move laterally within the network because access is limited to specific applications. This significantly strengthens internal security.

3. SECURE ACCESS FOR THIRD-PARTY VENDORS

Scenario:

Organizations often allow third-party vendors or contractors to access certain internal applications. Traditional VPNs typically grant vendors network-level access, which may expose sensitive systems. Using Zscaler Zero Trust, vendors are given restricted access only to the required application through identity-based authentication and policy enforcement.

Output:

Third-party users securely access only the assigned application without visibility into the rest of the network, minimizing insider and external security risks.

4. SECURE ACCESS TO CLOUD APPLICATIONS

Scenario:

Modern organizations use cloud services such as SaaS platforms and cloud-hosted applications. Traditional VPN routing forces users to connect through the corporate network before accessing cloud services, which increases latency and complexity. Zscaler enables direct and secure access to cloud applications through its cloud-native architecture.

Output:

Users experience faster and secure access to cloud applications while maintaining strong security controls and centralized policy management.

5. DEVICE-BASED ACCESS CONTROL

Scenario:

In legacy VPN models, devices connecting to the network are often not checked for security compliance. Zscaler integrates device posture verification to ensure that only secure and compliant devices can access enterprise applications.

Output:

Access is granted only to verified and secure devices, preventing compromised or unmanaged devices from accessing sensitive organizational resources.

STAGE -1

TITLE

Replace And Modernize Legacy VPN Architectures With A Cloud-Native Zscaler Zero Trust Solution to Reduce Attack Surface and Lateral Movement

OVERVIEW

Traditional **Virtual Private Network (VPN)** architectures have long been used by organizations to provide secure remote access to internal networks. However, these legacy VPN systems were designed for older network environments where most users and applications were located within a centralized infrastructure. With the growth of cloud computing, mobile workforces, and distributed systems, traditional VPN models have become less efficient and increasingly vulnerable to modern cybersecurity threats.

One of the major issues with legacy VPN architectures is that once a user is authenticated, they are often granted broad access to the internal network. This creates opportunities for attackers to move laterally across systems if a single device or user account is compromised. As a result, the network's **attack surface increases**, making it easier for cybercriminals to exploit vulnerabilities and gain access to sensitive organizational resources.

To address these security challenges, modern cybersecurity strategies are shifting toward the **Zero Trust security model**, which follows the principle of "Never Trust, Always Verify." Instead of trusting users or devices based on their network location, Zero Trust continuously verifies identity, device posture, and access permissions before allowing access to applications. This ensures that users are only granted **least-privileged access** to the specific resources they require.

A cloud-native platform such as **Zscaler Zero Trust** helps organizations replace traditional VPN infrastructure by providing secure, direct access to applications without exposing the internal network. By connecting users to applications through a secure cloud platform, Zscaler reduces the attack surface, prevents lateral movement, and improves overall network security while supporting modern cloud-based environments.

LIST OF VULNERABILITIES

S.NO	CATEGORY NAME	VULNERABILITY NAME	CWE N.O.
1.	Broken Access Control	Unintended Proxy or Intermediary ('Confused Deputy')	441
2.	Security Misconfiguration	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	614
3.	Software Supply Chain Failures	Reliance on Insufficiently Trustworthy Component	1357
4.	Cryptographic Failures	Incorrect Usage of Seeds in Pseudo-Random Number Generator(PRNG)	335
5.	Injection	Missing XML Validation	112
6.	Insecure Design	External Control of File Name or Path	73
7.	Authentication Failures	Improper Validation of Certificate with Host Mismatch	297
8.	Software or Data Integrity Failures	Replicating Malicious Code (Virus or Worm)	509
9.	Security Logging and Alerting Failures	Omission of Security-relevant Information	223
10.	Mishandling of Exceptional Conditions	Declaration of Catch for Generic Exception	396

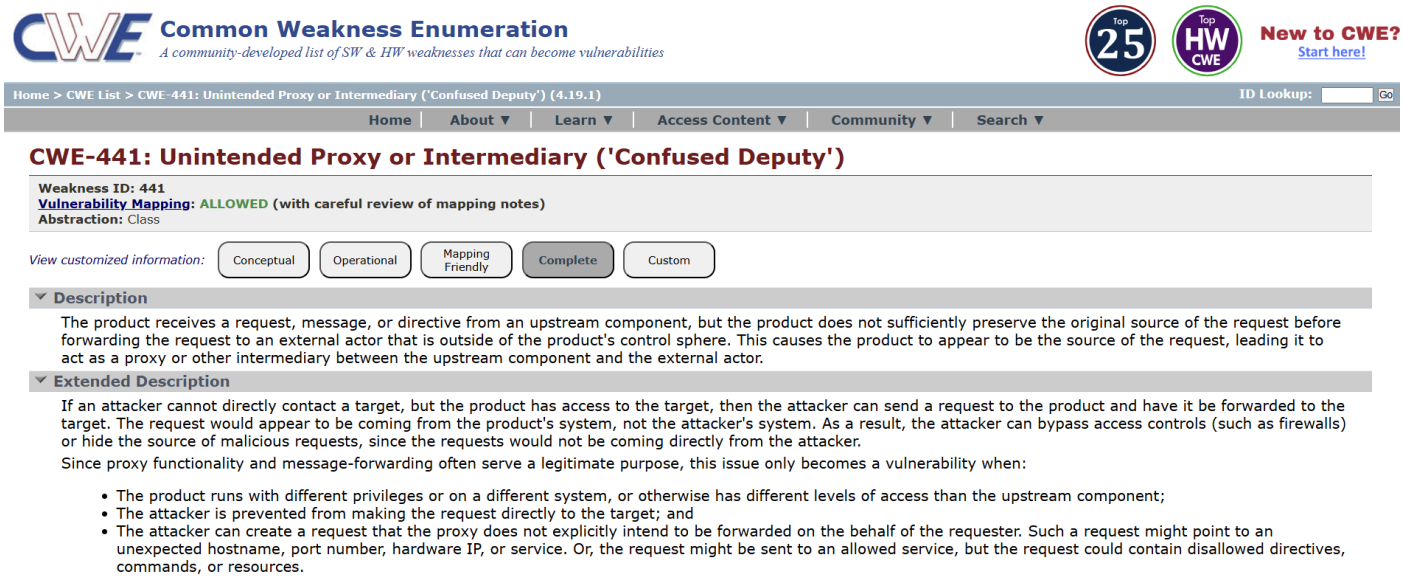
REPORT

VULNERABILITY 1

Vulnerability Name : Unintended Proxy or Intermediary ('Confused_Deputy')

CWE : 441

OWASP/SANS Category : OWASP Top 10 – A01: Broken Access Control



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-441: Unintended Proxy or Intermediary ('Confused Deputy') (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-441: Unintended Proxy or Intermediary ('Confused Deputy')

Weakness ID: 441
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product receives a request, message, or directive from an upstream component, but the product does not sufficiently preserve the original source of the request before forwarding the request to an external actor that is outside of the product's control sphere. This causes the product to appear to be the source of the request, leading it to act as a proxy or other intermediary between the upstream component and the external actor.

Extended Description

If an attacker cannot directly contact a target, but the product has access to the target, then the attacker can send a request to the product and have it be forwarded to the target. The request would appear to be coming from the product's system, not the attacker's system. As a result, the attacker can bypass access controls (such as firewalls) or hide the source of malicious requests, since the requests would not be coming directly from the attacker.

Since proxy functionality and message-forwarding often serve a legitimate purpose, this issue only becomes a vulnerability when:

- The product runs with different privileges or on a different system, or otherwise has different levels of access than the upstream component;
- The attacker is prevented from making the request directly to the target; and
- The attacker can create a request that the proxy does not explicitly intend to be forwarded on the behalf of the requester. Such a request might point to an unexpected hostname, port number, hardware IP, or service. Or, the request might be sent to an allowed service, but the request could contain disallowed directives, commands, or resources.

Description

The Confused Deputy vulnerability occurs when a program with higher privileges is tricked into performing actions on behalf of a less-privileged user. The system mistakenly uses its own authority to perform operations that the requesting user is not authorized to execute. As a result, an attacker may indirectly access protected resources by manipulating trusted components of the system.

Business Impact

This vulnerability may allow attackers to bypass access control mechanisms and gain unauthorized access to sensitive resources. It can lead to data exposure, unauthorized transactions, or misuse of privileged system operations, potentially causing financial loss and reputational damage.

Recommendation

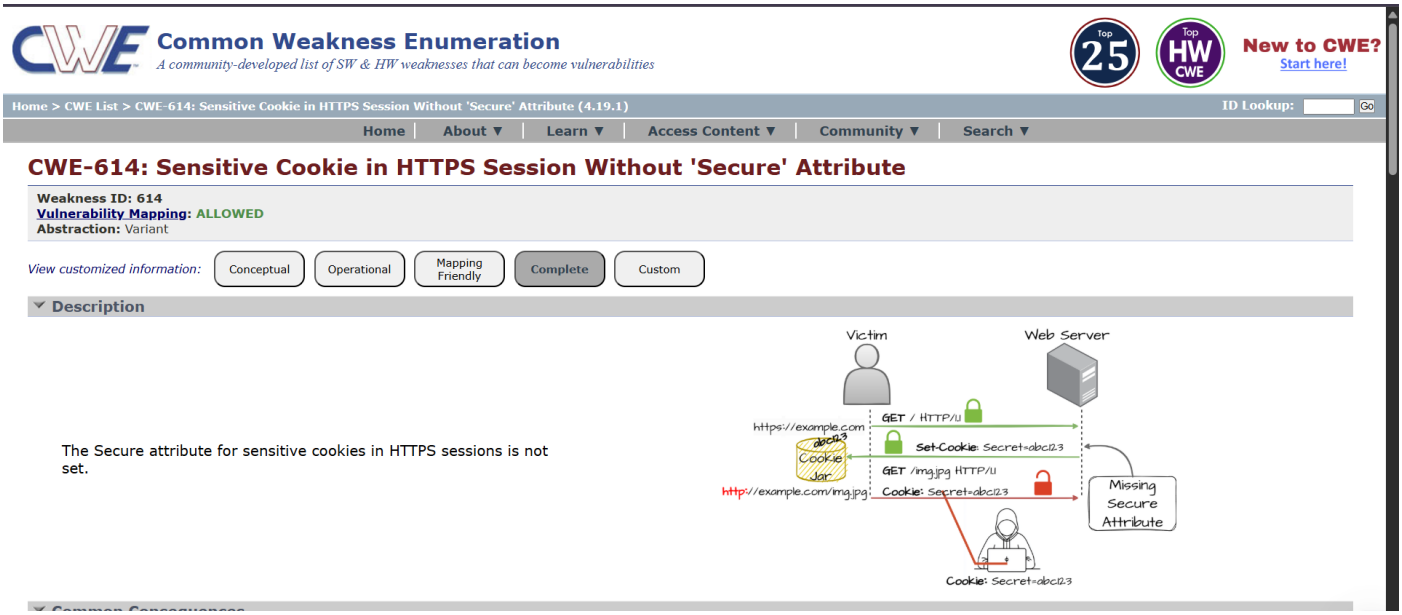
Ensure that applications verify the permissions of the requesting user before performing privileged operations. Implement strict access control validation and avoid allowing systems or services to act on behalf of users without proper authorization checks.

VULNERABILITY 2

Vulnerability Name : Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

CWE : 614

OWASP/SANS Category : OWASP Top 10 – A02: Security Misconfiguration



Description

This vulnerability occurs when cookies containing sensitive information are transmitted without the **Secure** attribute enabled. Without this attribute, cookies may be sent over unencrypted HTTP connections instead of HTTPS, making them vulnerable to interception.

Business Impact

Attackers may intercept session cookies through network sniffing or man-in-the-middle attacks, allowing them to hijack user sessions and gain unauthorized access to accounts or sensitive information.

Recommendation

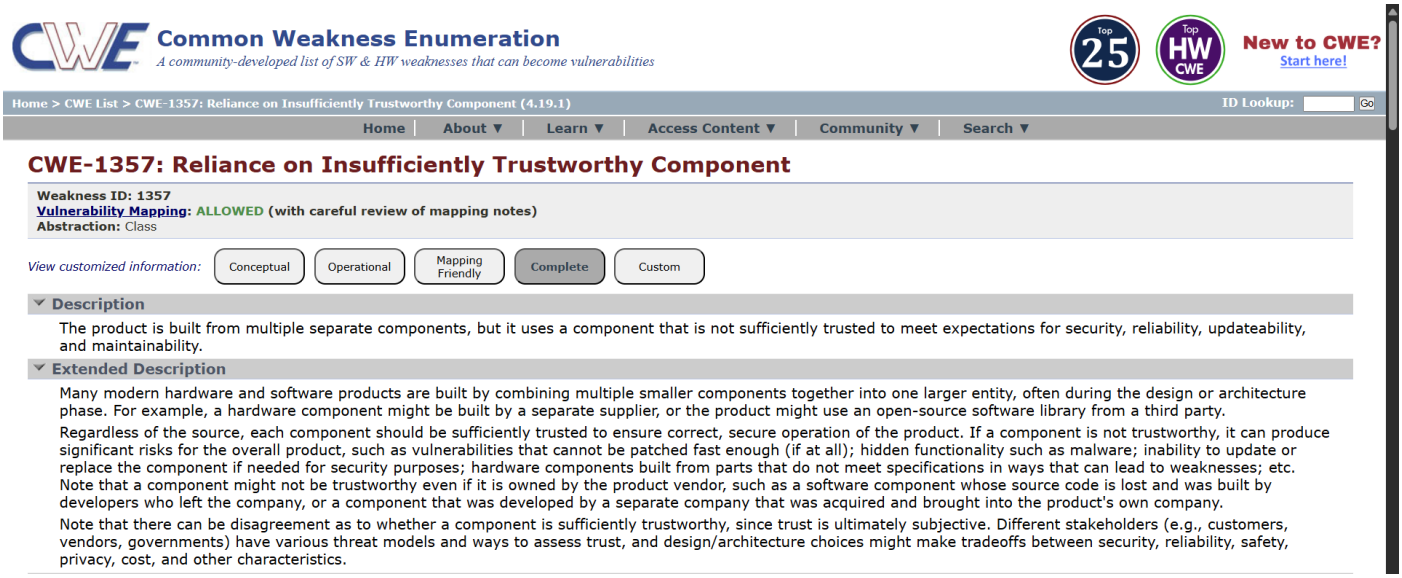
Always enable the **Secure attribute** for cookies used in HTTPS sessions. This ensures cookies are only transmitted over encrypted connections and reduces the risk of session hijacking.

VULNERABILITY 3

Vulnerability Name : Reliance on Insufficiently Trustworthy Component

CWE : *1357*

OWASP/SANS Category : OWASP Top 10 – A03: Software Supply Chain Failures



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-1357: Reliance on Insufficiently Trustworthy Component (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-1357: Reliance on Insufficiently Trustworthy Component

Weakness ID: 1357
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product is built from multiple separate components, but it uses a component that is not sufficiently trusted to meet expectations for security, reliability, updateability, and maintainability.

Extended Description

Many modern hardware and software products are built by combining multiple smaller components together into one larger entity, often during the design or architecture phase. For example, a hardware component might be built by a separate supplier, or the product might use an open-source software library from a third party.

Regardless of the source, each component should be sufficiently trusted to ensure correct, secure operation of the product. If a component is not trustworthy, it can produce significant risks for the overall product, such as vulnerabilities that cannot be patched fast enough (if at all); hidden functionality such as malware; inability to update or replace the component if needed for security purposes; hardware components built from parts that do not meet specifications in ways that can lead to weaknesses; etc. Note that a component might not be trustworthy even if it is owned by the product vendor, such as a software component whose source code is lost and was built by developers who left the company, or a component that was developed by a separate company that was acquired and brought into the product's own company.

Note that there can be disagreement as to whether a component is sufficiently trustworthy, since trust is ultimately subjective. Different stakeholders (e.g., customers, vendors, governments) have various threat models and ways to assess trust, and design/architecture choices might make tradeoffs between security, reliability, safety, privacy, cost, and other characteristics.

Description

This vulnerability occurs when an application depends on third-party components or libraries that are not adequately trusted, verified, or maintained. These components may contain hidden vulnerabilities or malicious code that can compromise the security of the application.

Business Impact

Attackers can exploit weaknesses in untrusted components to compromise systems, steal sensitive information, or disrupt application functionality. This can result in supply chain attacks affecting multiple systems.

Recommendation

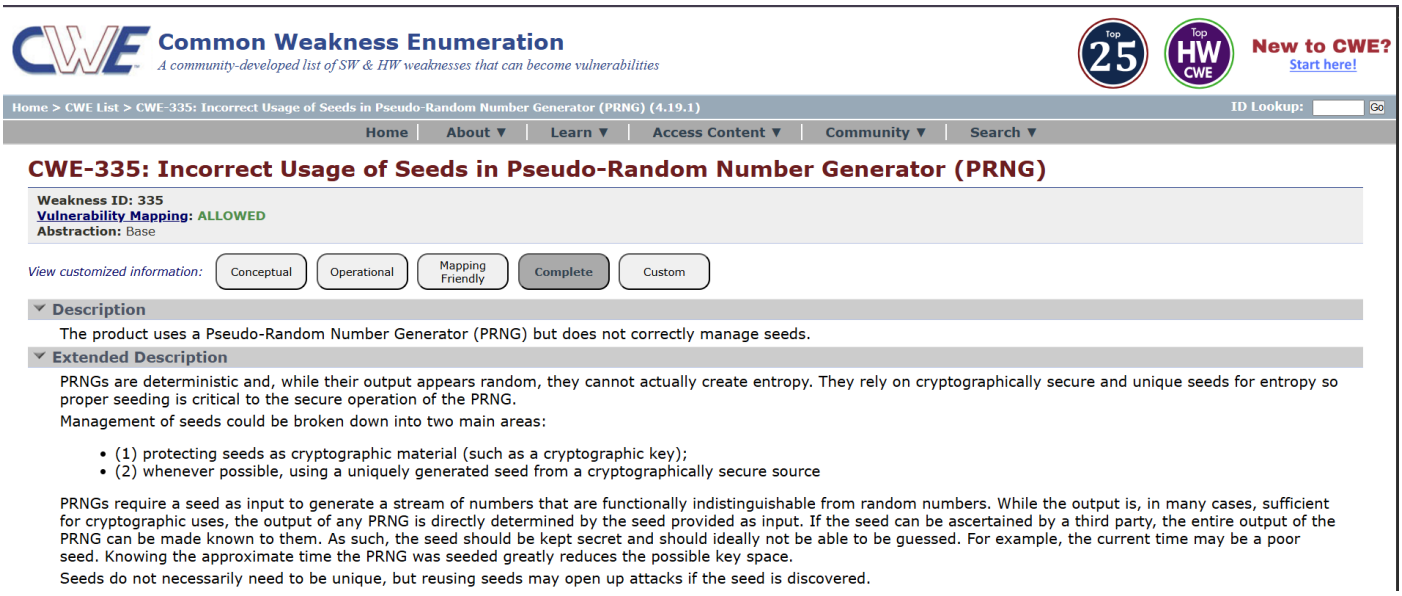
Use components only from trusted and verified sources. Regularly monitor dependencies for vulnerabilities, maintain an updated Software Bill of Materials (SBOM), and apply security patches or updates promptly.

VULNERABILITY 4

Vulnerability Name : Incorrect Usage of Seeds in Pseudo-Random Number Generator(PRNG)

CWE : 335

OWASP/SANS Category : OWASP Top 10 – A04: Cryptographic Failures



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-335: Incorrect Usage of Seeds in Pseudo-Random Number Generator (PRNG) (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-335: Incorrect Usage of Seeds in Pseudo-Random Number Generator (PRNG)

Weakness ID: 335
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses a Pseudo-Random Number Generator (PRNG) but does not correctly manage seeds.

Extended Description

PRNGs are deterministic and, while their output appears random, they cannot actually create entropy. They rely on cryptographically secure and unique seeds for entropy so proper seeding is critical to the secure operation of the PRNG.

Management of seeds could be broken down into two main areas:

- (1) protecting seeds as cryptographic material (such as a cryptographic key);
- (2) whenever possible, using a uniquely generated seed from a cryptographically secure source

PRNGs require a seed as input to generate a stream of numbers that are functionally indistinguishable from random numbers. While the output is, in many cases, sufficient for cryptographic uses, the output of any PRNG is directly determined by the seed provided as input. If the seed can be ascertained by a third party, the entire output of the PRNG can be made known to them. As such, the seed should be kept secret and should ideally not be able to be guessed. For example, the current time may be a poor seed. Knowing the approximate time the PRNG was seeded greatly reduces the possible key space.

Seeds do not necessarily need to be unique, but reusing seeds may open up attacks if the seed is discovered.

Description

This vulnerability occurs when predictable or improperly generated seed values are used in pseudo-random number generators. Weak or predictable seeds can lead to predictable random numbers, weakening cryptographic operations such as key generation or session tokens.

Business Impact

Predictable random values can allow attackers to guess cryptographic keys, authentication tokens, or session identifiers. This can lead to unauthorized access, data breaches, or compromised encryption mechanisms.

Recommendation

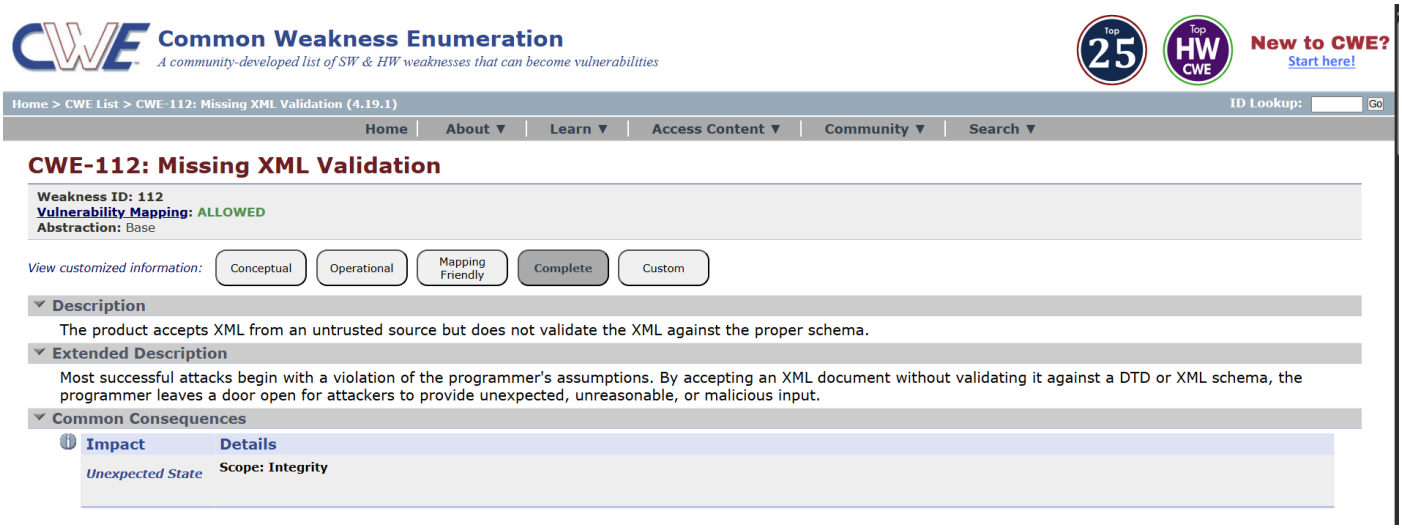
Use cryptographically secure random number generators (CSPRNG) and ensure that seed values are generated with sufficient entropy. Avoid predictable seed sources such as timestamps or fixed values.

VULNERABILITY 5

Vulnerability Name : Missing XML Validation

CWE : *112*

OWASP/SANS Category : OWASP Top 10 – A05: Injection



Description

Missing XML validation occurs when applications fail to validate XML input against defined schemas or structures. Without proper validation, malicious XML content can be processed by the application, potentially leading to injection attacks or unauthorized data manipulation.

Business Impact

Attackers may exploit malformed XML data to manipulate application logic, access sensitive information, or execute malicious operations, which can compromise system integrity.

Recommendation

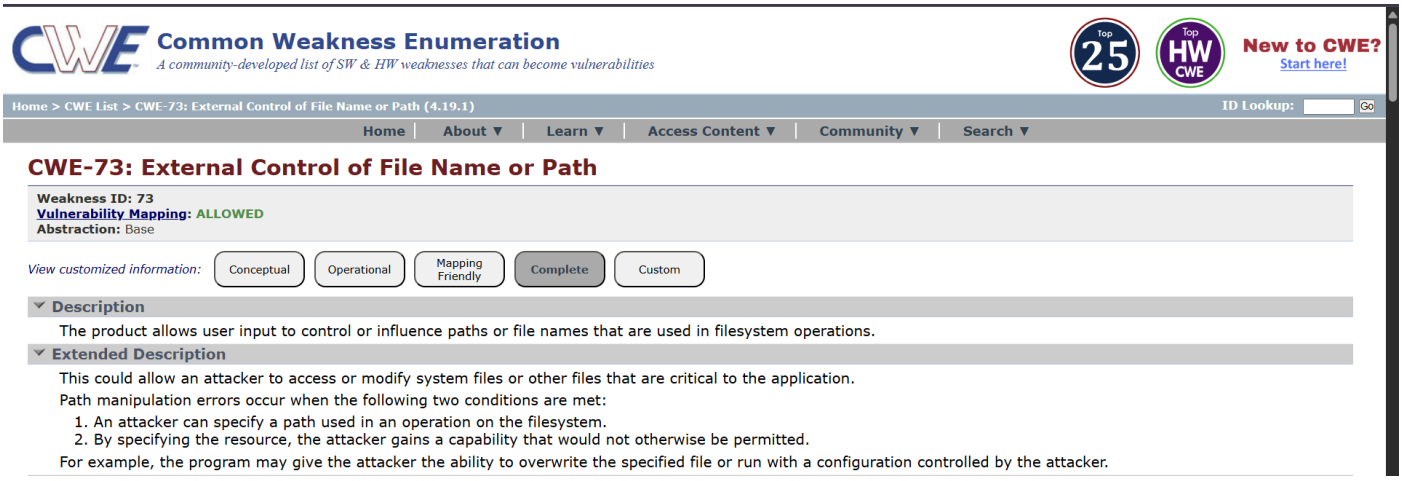
Validate all XML inputs against a predefined schema before processing. Implement strict input validation and secure parsing mechanisms to prevent XML-based attacks.

VULNERABILITY 6

Vulnerability Name : External Control of File Name or Path

CWE : 73

OWASP/SANS Category : OWASP Top 10 – A06: Insecure Design



Description

This vulnerability occurs when user input is used to construct file names or paths without proper validation. Attackers may manipulate file paths to access unauthorized files or directories within the system.

Business Impact

Attackers can access sensitive files, modify system resources, or execute unauthorized operations, potentially leading to data leakage or system compromise.

Recommendation

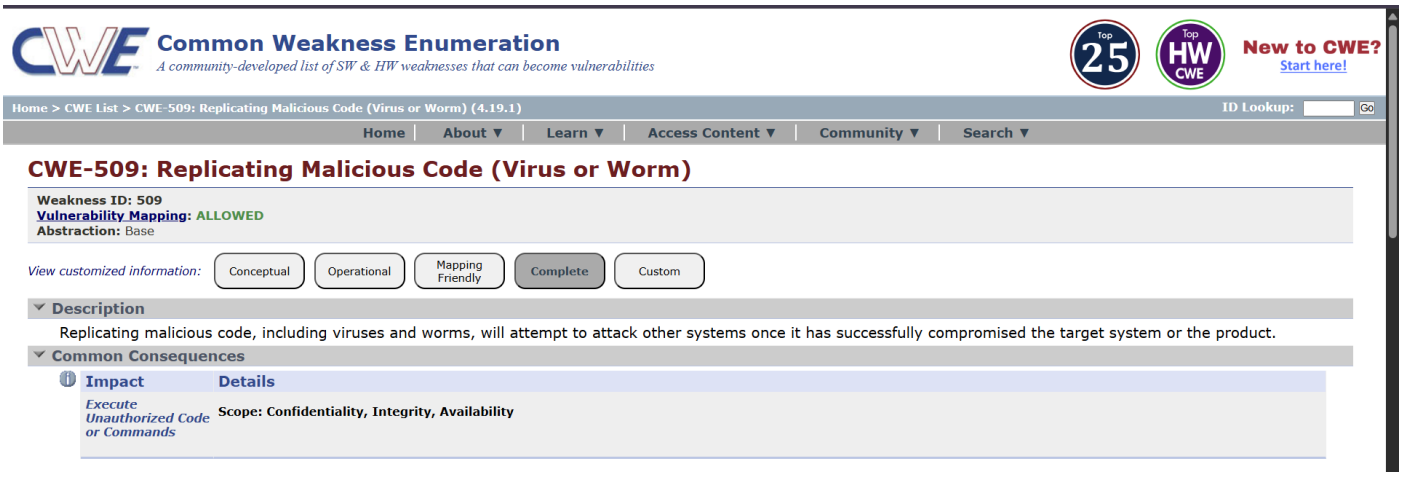
Validate and sanitize all user input used in file operations. Restrict file access to predefined directories and implement strong access control mechanisms.

VULNERABILITY 7

Vulnerability Name : Improper Validation of Certificate with Host Mismatch

CWE : 297

OWASP/SANS Category : OWASP Top 10 – A07: Authentication Failures



Description

This vulnerability occurs when a system fails to properly verify whether a server's certificate matches the intended hostname. As a result, an attacker may present a valid certificate for another domain and still be accepted as a trusted entity.

Business Impact

Attackers can perform man-in-the-middle attacks, intercepting and manipulating sensitive communication between clients and servers.

Recommendation

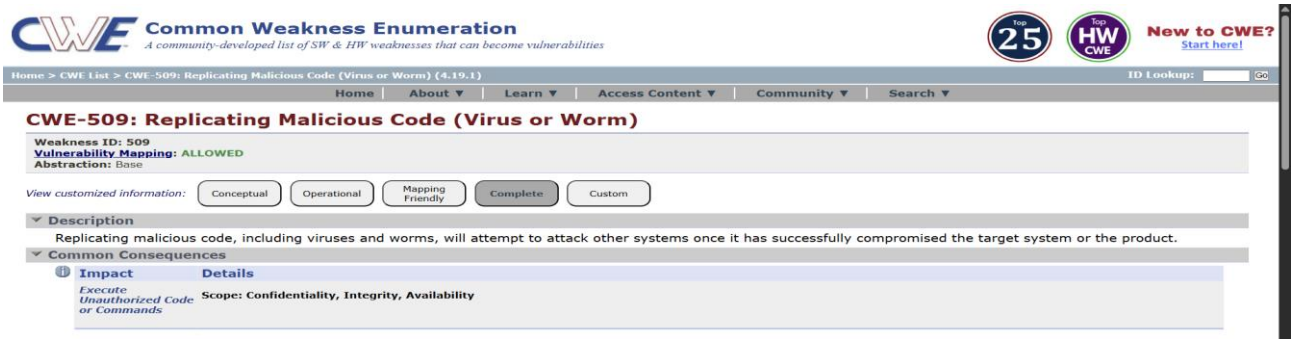
Ensure proper validation of SSL/TLS certificates by verifying that the certificate's hostname matches the intended domain before establishing a secure connection.

VULNERABILITY 8

Vulnerability Name : Replicating Malicious Code (Virus or Worm)

CWE : 509

OWASP/SANS Category : OWASP Top 10 – A08: Software or Data Integrity Failures



Description

This vulnerability refers to the presence of self-replicating malicious code such as viruses or worms within software components. Such code can spread across systems and compromise application integrity.

Business Impact

Malicious code replication can lead to system compromise, data corruption, service disruption, and large-scale security breaches within organizational networks.

Recommendation

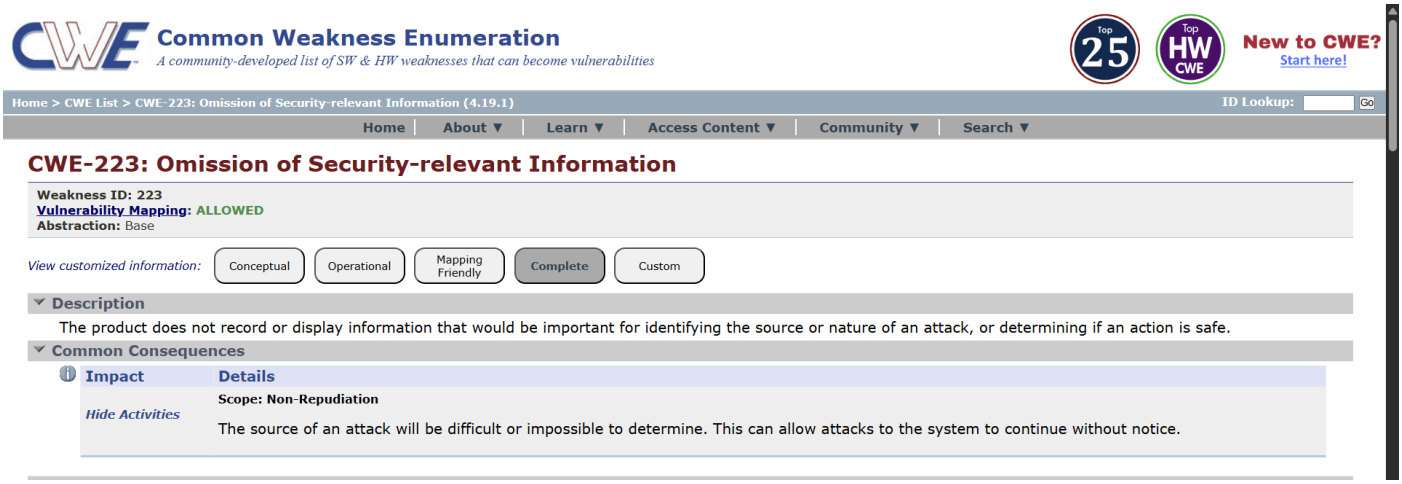
Implement strong malware detection mechanisms, secure code review processes, and software integrity verification to prevent malicious code from entering systems.

VULNERABILITY 9

Vulnerability Name : Omission of Security-relevant Information

CWE : 223

OWASP/SANS Category : OWASP Top 10 – A09: Security Logging and Alerting Failures



Description

This vulnerability occurs when applications fail to record important security-related events in logs. Without sufficient logging, suspicious or malicious activities may go undetected.

Business Impact

Lack of logging can prevent organizations from detecting cyberattacks, investigating incidents, or responding to security breaches effectively.

Recommendation

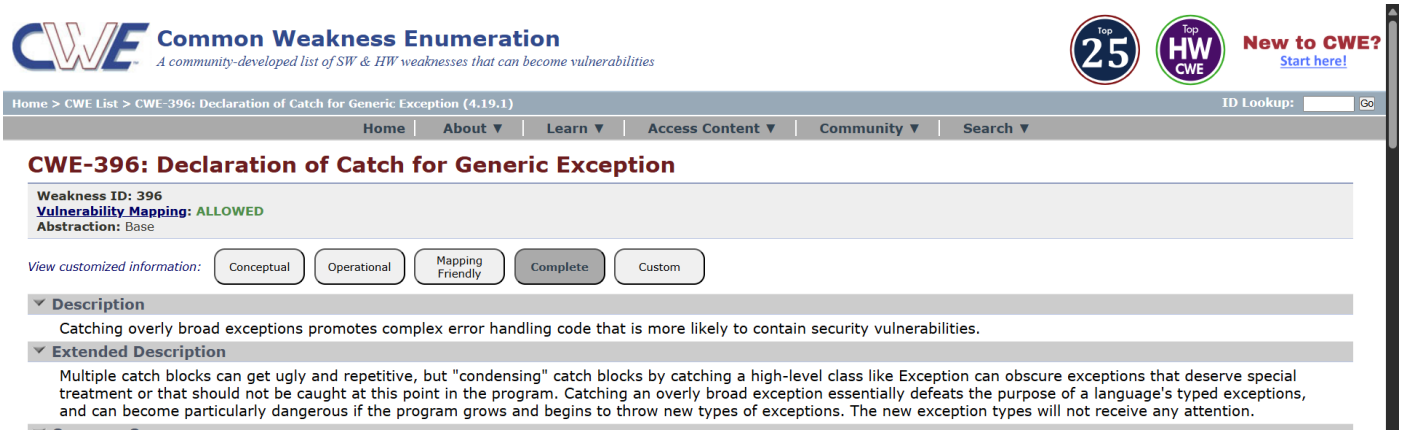
Implement comprehensive logging for security events such as authentication attempts, access control violations, and system errors. Logs should be monitored and protected against tampering.

VULNERABILITY 10

Vulnerability Name : Declaration of Catch for Generic Exception

CWE : 396

OWASP/SANS Category : OWASP Top 10 – A10: Mishandling of Exceptional Conditions



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25 | Top HW CWE | New to CWE? Start here!

Home > CWE List > CWE-396: Declaration of Catch for Generic Exception (4.19.1) | ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-396: Declaration of Catch for Generic Exception

Weakness ID: 396
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

Catching overly broad exceptions promotes complex error handling code that is more likely to contain security vulnerabilities.

Extended Description

Multiple catch blocks can get ugly and repetitive, but "condensing" catch blocks by catching a high-level class like Exception can obscure exceptions that deserve special treatment or that should not be caught at this point in the program. Catching an overly broad exception essentially defeats the purpose of a language's typed exceptions, and can become particularly dangerous if the program grows and begins to throw new types of exceptions. The new exception types will not receive any attention.

Description

This vulnerability occurs when applications use generic exception handlers that catch all exceptions without distinguishing specific error conditions. This can hide underlying issues and prevent proper handling of errors.

Business Impact

Improper exception handling can cause system instability, hide critical security issues, and make debugging or incident investigation difficult.

Recommendation

Use specific exception handlers instead of generic ones and implement proper error handling mechanisms to ensure errors are correctly managed and logged.

STAGE -2

OVERVIEW

Tenable Nessus is one of the most widely used **vulnerability assessment tools** in the field of cybersecurity. Developed by **Tenable Inc.**, Nessus helps organizations identify, analyse, and manage security vulnerabilities present in networks, systems, and applications. It is designed to perform automated vulnerability scanning that detects weaknesses such as outdated software, misconfigurations, missing patches, and potential security flaws that attackers could exploit. By providing detailed insights into security risks, Nessus enables organizations to proactively strengthen their cybersecurity posture and reduce the chances of cyberattacks.

Nessus works by scanning target systems such as servers, workstations, databases, web applications, and network devices using a large collection of continuously updated vulnerability checks called **plugins**. These plugins contain information about thousands of known vulnerabilities, security misconfigurations, malware threats, and compliance issues. During a scan, Nessus compares the configuration and software versions of the target system with its vulnerability database to identify potential weaknesses. The results are then presented in a detailed report that includes the severity level of vulnerabilities, risk scores, and recommended remediation steps.

One of the major strengths of Tenable Nessus is its ability to provide **comprehensive vulnerability management** through accurate detection and detailed reporting. The tool categorizes vulnerabilities into different severity levels such as **Critical, High, Medium, Low, and Informational**, allowing security teams to prioritize remediation efforts based on risk impact. Nessus also supports authenticated and unauthenticated scans, enabling deeper analysis of systems when proper credentials are provided. This helps in identifying internal vulnerabilities such as weak configurations, outdated software packages, and security policy violations.

In modern cybersecurity environments, tools like Nessus play a crucial role in **continuous security monitoring and risk assessment**. Organizations use Nessus to regularly scan their infrastructure, identify new vulnerabilities, and ensure compliance with security standards. By integrating vulnerability assessment into the security workflow, Nessus helps organizations reduce their attack surface, improve system security, and maintain a proactive defense strategy against emerging cyber threats.

TARGET WEBSITE : *demo.testfire.net*

TARGET IP ADDRESS : 65.61.137.117

LIST OF VULNERABILITIES

S.NO	VULNERABILITY NAME	SEVERITY	PLUGINS ID
1.	TLS Version 1.0 Protocol Detection	Medium	104743
2.	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	Low	83875
3.	ICMP Timestamp Request Remote Date Disclosure	Low	10114
4.	Service Detection	Info	22964
5.	OS Fingerprints Detected	Info	209654

REPORT

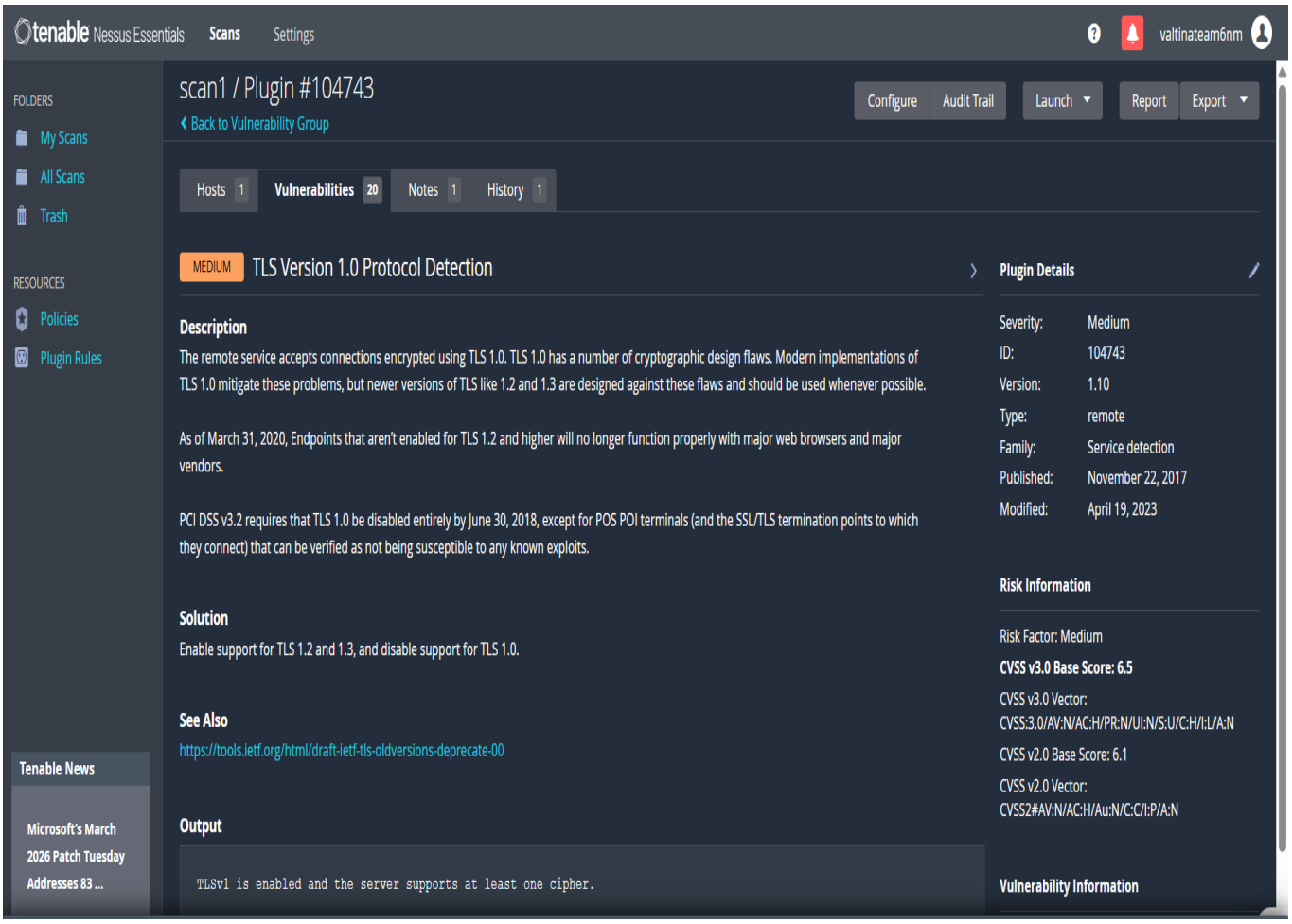
VULNERABILITY -1

Vulnerability Name : TLS Version 1.0 Protocol Detection

Severity : Medium

Plugin : 104743

Port : 443



Description:

The remote server accepts encrypted connections using **TLS 1.0**, which is an outdated cryptographic protocol. TLS 1.0 contains several cryptographic design weaknesses that can potentially be exploited by attackers. Although some modern implementations attempt to mitigate these flaws, newer versions such as **TLS 1.2 and TLS 1.3** provide stronger security mechanisms and improved encryption standards. As a result, TLS 1.0 is considered deprecated and is no longer supported by major web browsers and security standards.

Solution:

Disable support for **TLS 1.0** on the server and enable stronger encryption protocols such as **TLS 1.2 and TLS 1.3**. Updating the server configuration to use modern cryptographic protocols will ensure stronger encryption, improved security, and compliance with current security standards.

Output:

The scan result indicates that **TLSv1 is enabled on the server**, and the server supports at least one cipher suite using this protocol. The service was detected on **TCP port 443 (HTTPS)** of the target host.

Business Impact:

Using outdated encryption protocols like **TLS 1.0** exposes the system to potential security risks such as **man-in-the-middle attacks, data interception, and cryptographic exploits**. Attackers may exploit these weaknesses to compromise sensitive data transmitted between clients and the server. Additionally, continued use of TLS 1.0 may result in **non-compliance with security standards such as PCI DSS**, which can lead to regulatory penalties, operational disruptions, and reputational damage.

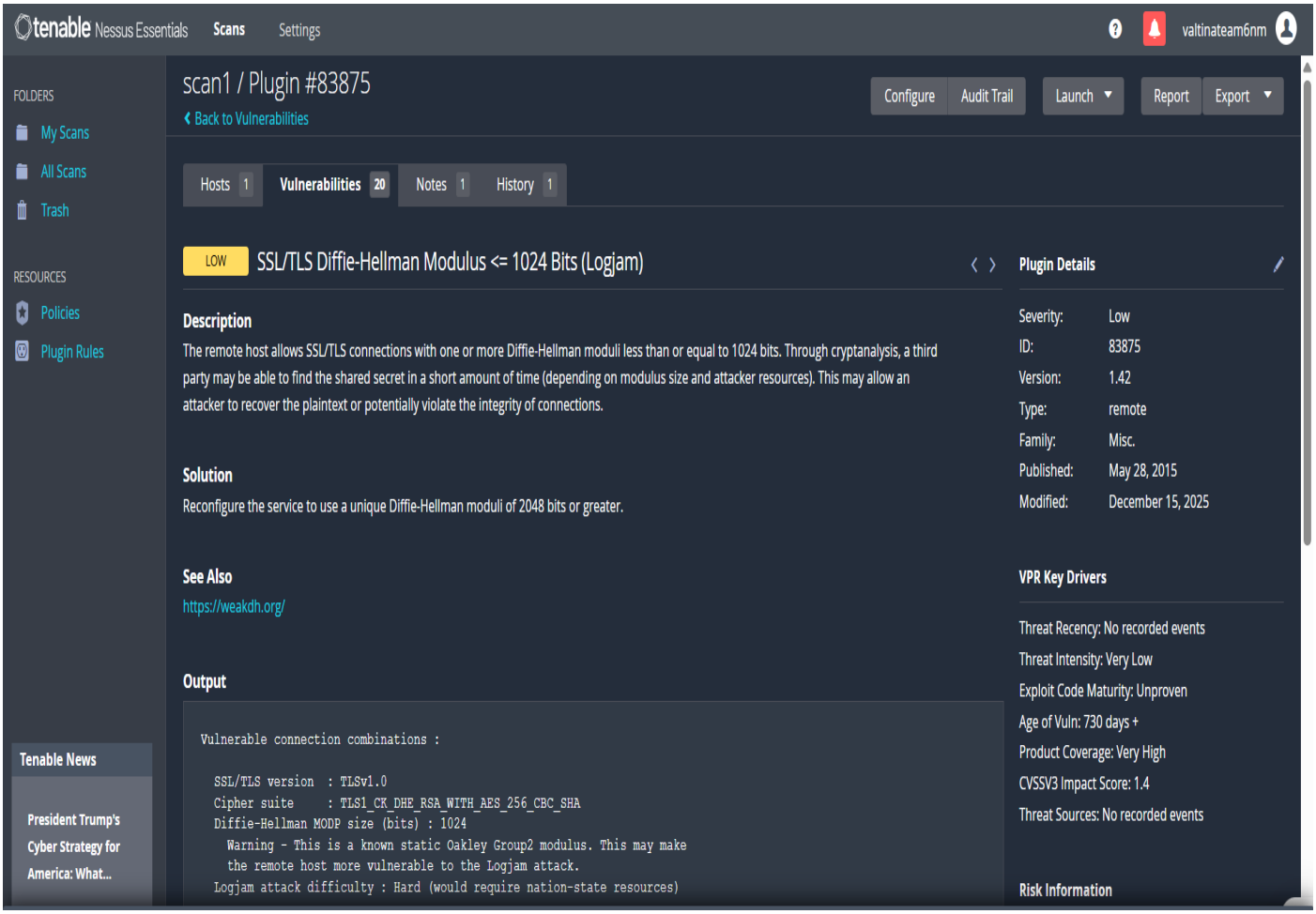
VULNERABILITY -2

Vulnerability Name : SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity **:** Low

Plugin **:** 83875

Port **:** 443



Description:

The remote host supports SSL/TLS connections using **Diffie-Hellman key exchange parameters with a modulus size of 1024 bits or less**. Weak Diffie-Hellman parameters make the encryption susceptible to cryptographic attacks such as the **Logjam attack**. Through advanced cryptanalysis, attackers may be able to compute the shared secret used during the key exchange process. If successful, this could allow attackers to decrypt encrypted communications or compromise the integrity of the secure connection.

Solution:

Reconfigure the server to use **strong Diffie-Hellman parameters with a modulus size of at least 2048 bits or greater**. Additionally, disable weak cipher suites and outdated TLS versions, and ensure the server uses modern encryption standards to strengthen communication security.

Business Impact:

Weak Diffie-Hellman parameters reduce the strength of encrypted communications and may expose sensitive data to attackers. If exploited, attackers could perform **man-in-the-middle attacks**, intercept encrypted data, or decrypt confidential information transmitted between users and the server. This can lead to **data breaches, unauthorized data access, and loss of trust in the system's security mechanisms**.

Output:

The scan detected multiple vulnerable SSL/TLS configurations using **Diffie-Hellman parameters of 1024 bits**. The affected cipher suites include:

- TLSv1.0 – TLS1_CK_DHE_RSA_WITH_AES_256_CBC_SHA
- TLSv1.0 – TLS1_CK_DHE_RSA_WITH_AES_128_CBC_SHA
- TLSv1.1 – TLS1_CK_DHE_RSA_WITH_AES_256_CBC_SHA
- TLSv1.1 – TLS1_CK_DHE_RSA_WITH_AES_128_CBC_SHA

All detected configurations use a **1024-bit Diffie-Hellman modulus (Oakley Group2)**, which increases the server's exposure to the **Logjam attack**.

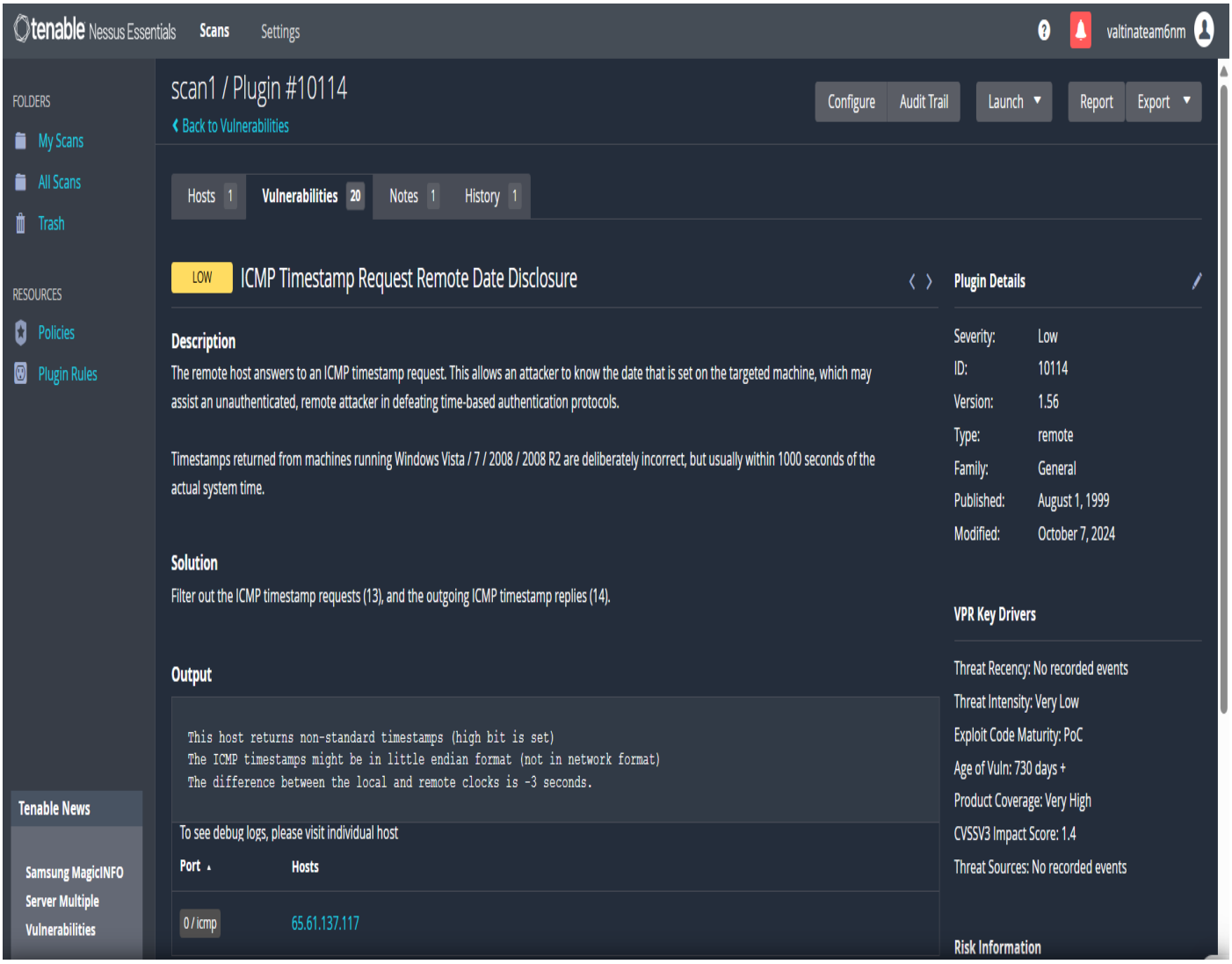
VULNERABILITY -3

Vulnerability Name : ICMP Timestamp Request Remote Date Disclosure

Severity **:** Low

Plugin **:** 10114

Port **:** 0



Description:

The remote host responds to **ICMP timestamp requests**, which allows remote users to determine the system time configured on the server. This information can potentially assist attackers in analyzing the system environment or bypassing certain security mechanisms that rely on time-based authentication. Although the timestamps returned by some systems may not always be perfectly accurate, they can still reveal approximate system time information to unauthorized users.

Solution:

Disable or filter **ICMP timestamp request (Type 13)** and **ICMP timestamp reply (Type 14)** messages on the firewall or network device. Restricting these responses prevents unauthorized users from retrieving system time information from the server.

Business Impact:

By obtaining the system time of the remote host, attackers may gain useful information that can assist in **reconnaissance and time-based attacks**. This information can help attackers synchronize their attacks, bypass time-based authentication mechanisms, or gather details about the system configuration. While the direct risk is generally low, it still contributes to **information disclosure that can aid further attacks**.

Output:

The scan indicates that the host responds to ICMP timestamp requests. The returned timestamp appears to be **non-standard**, with the high bit set, and may use **little-endian format instead of the network byte order**. The detected time difference between the local system and the remote host is **-3 seconds**.

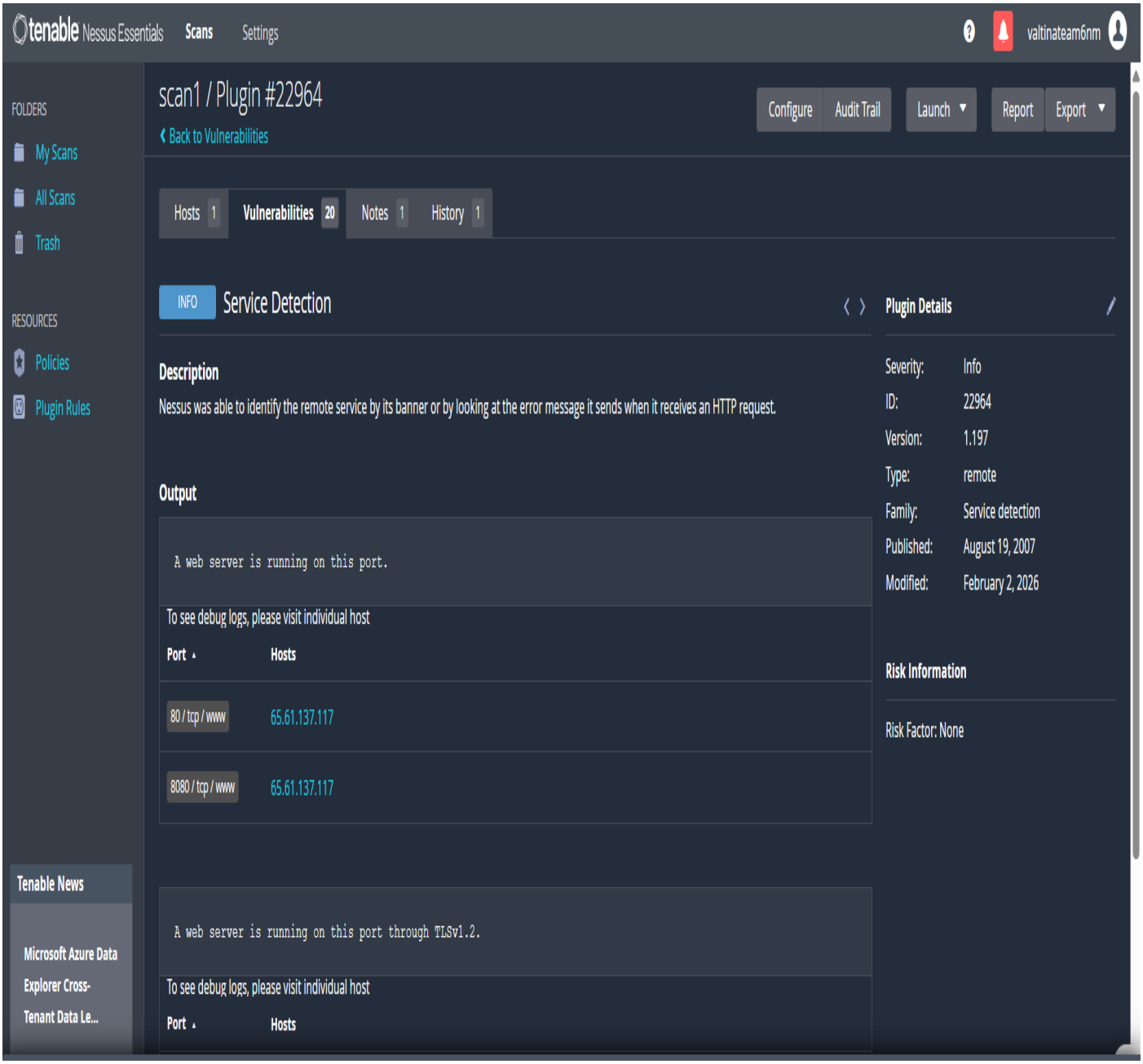
VULNERABILITY- 4

Vulnerability Name : Service Detection

Severity **:** Info

Plugin **:** 22964

Port **:** 443



Description:

The scan detected that a **web service is running on the remote host**, which was identified through service banner information or HTTP error responses returned by the server. Service detection allows vulnerability scanners to determine the type of service and protocol running on a specific port. In this case, the system is running web services over standard HTTP and HTTPS ports.

Solution:

Restrict unnecessary service exposure and ensure that all running services are **properly secured and updated**. Disable unused ports and services where possible, and configure firewalls to limit access only to authorized users.

Business Impact:

Service detection itself is informational, but it reveals **details about active services running on the server**. Attackers can use this information during the reconnaissance phase to identify potential targets and exploit known vulnerabilities in the detected services or web applications.

Output:

The scan identified active web services on the following ports of the target host **65.61.137.117**:

- **Port 80 / TCP (HTTP)** – Web server detected
- **Port 8080 / TCP (HTTP)** – Web server detected
- **Port 443 / TCP (HTTPS)** – Web server detected running with **TLSv1.2**

The server responded to HTTP requests, allowing Nessus to identify the running web services.

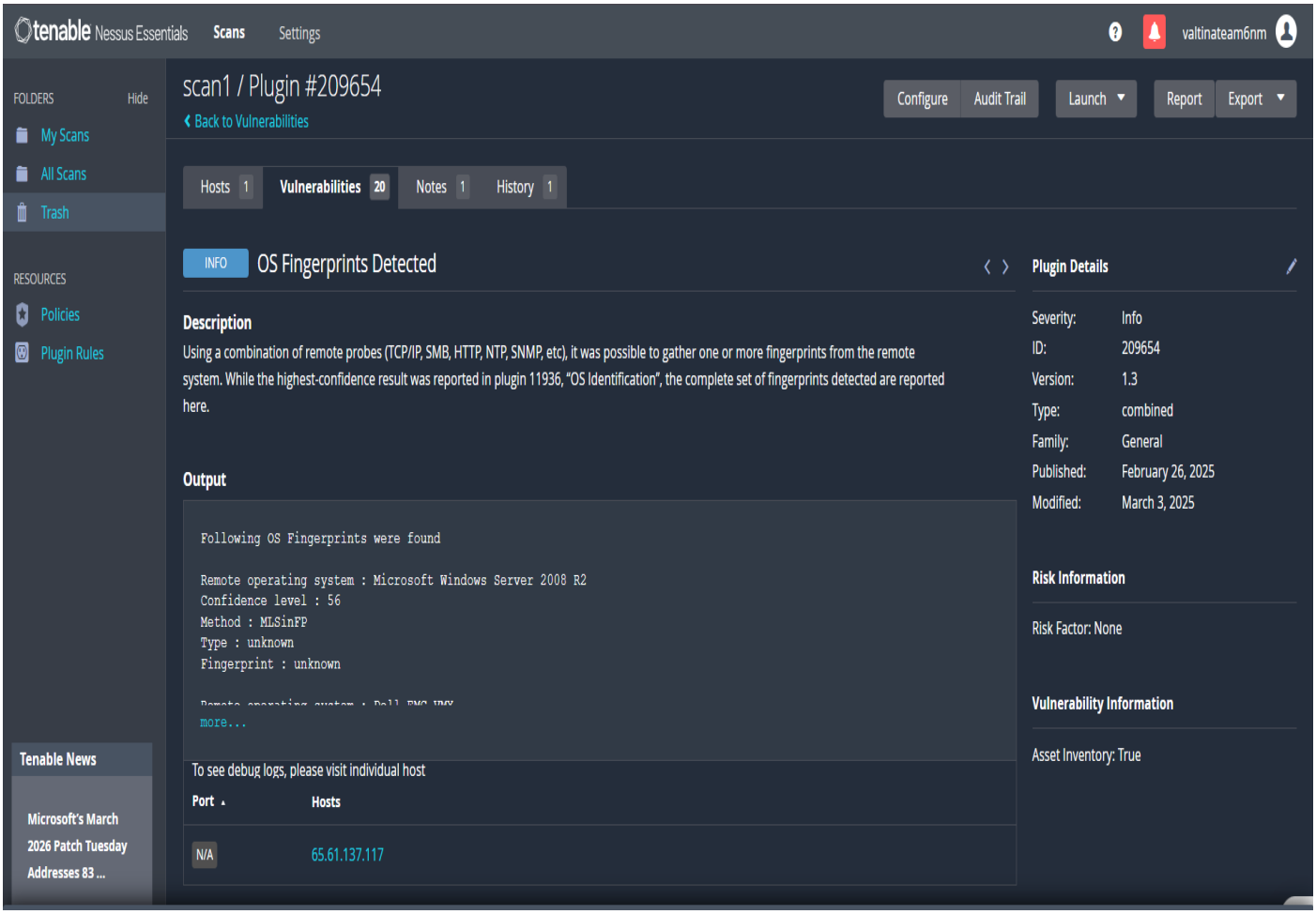
VULNERABILITY -5

Vulnerability Name : OS Fingerprints Detected

Severity : Info

Plugin : 209654

Port : N/A



Description:

The scan detected **operating system fingerprints** from the remote host using various network probes such as TCP/IP, HTTP, SNMP, and other protocols. OS fingerprinting is a technique used to identify the operating system running on a remote system by analysing responses to specially crafted network requests. Based on the collected fingerprints, the system appears to be running **Microsoft Windows Server 2008 R2** or **Microsoft Windows Embedded Standard 7**, though the confidence level of identification is moderate.

Solution:

Limit unnecessary information disclosure by restricting service banners and system responses that reveal operating system details. Implement proper firewall rules and security configurations to reduce the ability of attackers to perform OS fingerprinting on the system.

Business Impact:

OS fingerprinting reveals information about the **underlying operating system of the target host**, which can assist attackers during the reconnaissance phase of an attack. By identifying the operating system and system type, attackers may search for **known vulnerabilities specific to that platform**, potentially increasing the risk of targeted exploitation.

Output:

The scan detected the following possible operating system fingerprints from the target host:

- **Microsoft Windows Server 2008 R2**
  Confidence Level: 56%
- **Dell EMC VMX – Microsoft Windows Embedded Standard 7**
  Confidence Level: 59%

Additional fingerprint information was obtained through HTTP and SSL certificate analysis, including the presence of **Apache-Coyote/1.1** and a certificate associated with **demo.testfire.net**.

STAGE -3

TITLE

Replace And Modernize Legacy VPN Architectures With A Cloud-Native Zscaler Zero Trust Solution to Reduce Attack Surface and Lateral Movement

1. OVERVIEW OF LEGACY VPN ARCHITECTURE

Legacy VPN architectures were designed to provide secure remote connectivity between users and corporate networks through encrypted tunnels. These systems were effective when organizations operated primarily within centralized on-premise infrastructures. VPN solutions allow users to connect remotely to enterprise resources while maintaining secure communication over public networks.

However, modern enterprise environments have evolved significantly with the rise of **cloud services, distributed applications, and remote workforces**. Traditional VPNs often expose entire internal networks to authenticated users, increasing security risks and making them vulnerable to cyber threats.

Key Characteristics of Legacy VPN

- Encrypted tunnels between users and corporate networks
- Centralized gateway access
- Network-level access to internal resources
- Dependence on hardware appliances

Feature	Legacy VPN Behaviour
Access Model	Network-based access
Security Approach	Trust once authenticated
Infrastructure	On-premise VPN gateways
Scalability	Limited

2. SECURITY CHALLENGES OF TRADITIONAL VPN

Although VPNs provide encrypted communication, they introduce several security challenges. Once a user connects through a VPN, they often gain access to the entire internal network. If attackers compromise credentials or devices, they can exploit this trust to move freely within the network.

Additionally, VPN gateways may become **single points of failure** and are frequently targeted by attackers. Vulnerabilities in VPN software can allow unauthorized access or exploitation of the system.

Major Security Risks

- Credential theft attacks
- VPN gateway exploitation
- Lack of granular access control
- Exposure of internal network infrastructure

3. CONCEPT OF ZERO TRUST SECURITY MODEL

The Zero Trust security model is a modern cybersecurity framework that eliminates the concept of implicit trust within networks. Instead of assuming that users inside the network are trustworthy, Zero Trust requires continuous verification of identity, device health, and access permissions.

This model follows the principle of **"Never Trust, Always Verify."** Access to resources is granted only after validating the user's identity and ensuring compliance with security policies.

Core Principles of Zero Trust

1. Verify identity continuously
2. Implement least-privilege access
3. Assume breach mentality
4. Monitor and log every access attempt

4. CLOUD-NATIVE SECURITY ARCHITECTURE

Cloud-native security architectures operate through distributed cloud platforms instead of traditional on-premise security appliances. These platforms provide scalable security services that can support users from any location.

Unlike VPNs that route traffic through centralized gateways, cloud-native architectures allow users to connect directly to applications while security checks are performed in the cloud.

Benefits of Cloud-Native Security

- Improved scalability
- Reduced infrastructure complexity
- Faster access to cloud applications
- Consistent policy enforcement

5. ZSCALER ZERO TRUST PLATFORM

Zscaler is a leading cloud-native cybersecurity platform that enables organizations to implement Zero Trust security. It provides secure connectivity between users and applications without exposing the internal network.

The platform operates through the **Zscaler Zero Trust Exchange**, which acts as an intermediary that verifies user identity and device security before allowing access to applications.

Core Components of Zscaler

Component	Function
Zscaler Internet Access (ZIA)	Secure internet access
Zscaler Private Access (ZPA)	Secure application access
Zscaler Digital Experience (ZDX)	Performance monitoring

6. REDUCING ATTACK SURFACE USING ZSCALER

The attack surface refers to all potential points where attackers can attempt to compromise a system. Traditional VPN architectures increase the attack surface by exposing internal network resources to external users.

Zscaler reduces the attack surface by hiding internal applications from the internet and allowing access only through authenticated and verified connections.

Methods to Reduce Attack Surface

- Application-level access instead of network-level access
- Identity-based authentication
- Continuous monitoring of access requests

7. PREVENTING LATERAL MOVEMENT IN NETWORKS

Lateral movement occurs when attackers move across systems within a compromised network to locate valuable data or sensitive resources. In VPN-based networks, attackers can explore multiple systems once they gain initial access.

Zero Trust architecture prevents lateral movement by restricting access to only the specific application required by the user.

Techniques Used

- Micro-segmentation
- Continuous identity verification
- Network isolation

8. IMPLEMENTATION WORKFLOW OF ZSCALER ZERO TRUST

The deployment of Zscaler Zero Trust involves several stages, including identity verification, policy enforcement, and secure application access.

Workflow Steps

1. User attempts to access an application
2. Identity verification through authentication mechanisms
3. Device posture assessment
4. Policy evaluation
5. Secure connection to the authorized application

This workflow ensures that unauthorized users or compromised devices cannot access enterprise resources.

9. ADVANTAGES OF REPLACING VPN WITH ZSCALER

Replacing traditional VPN solutions with Zscaler Zero Trust provides multiple benefits in terms of security, performance, and scalability.

Advantages

- Eliminates implicit trust in networks
- Reduces attack surface
- Prevents lateral movement
- Simplifies network management
- Improves application performance

Aspect	VPN	Zscaler Zero Trust
Access Type	Network-level	Application-level
Security Model	Trust-based	Zero Trust
Infrastructure	Hardware appliances	Cloud-based

10. Future of Secure Remote Access

The future of enterprise security lies in identity-driven architectures rather than network-based security models. With the increasing adoption of cloud services and remote work environments, organizations must move beyond traditional VPN infrastructures.

Zero Trust solutions like Zscaler enable organizations to secure modern digital environments while maintaining flexibility and scalability. These solutions provide continuous protection against evolving cyber threats and support secure digital transformation.

CONCLUSION

This project examined the security challenges associated with traditional VPN-based remote access and proposed a modern approach using a **cloud-native Zero Trust architecture with Zscaler**.

In **Stage 1**, the study focused on understanding major cybersecurity risks by analysing vulnerabilities mapped to the **OWASP Top 10 and their corresponding CWE categories**. This stage helped identify how weaknesses such as broken access control, cryptographic flaws, and security misconfigurations can expose systems to unauthorized access, data leakage, and other cyber threats.

In **Stage 2**, practical vulnerability assessment was performed using the **Tenable Nessus scanning tool** on the target website. The scan results revealed several vulnerabilities including outdated encryption protocols, weak cryptographic configurations, and information disclosure issues. These findings demonstrate the importance of continuous vulnerability assessment in identifying security weaknesses and implementing appropriate remediation measures before attackers exploit them.

In **Stage 3**, the project explored the concept of replacing legacy VPN architectures with the **Zscaler Zero Trust security model**. By enforcing identity-based authentication, least-privilege access, and application-level connectivity, the Zero Trust approach significantly reduces the attack surface and prevents lateral movement within networks. Overall, the study highlights that combining **Zero Trust architecture with continuous vulnerability monitoring** provides a stronger, scalable, and future-ready security framework for protecting modern enterprise environments.

FUTURE ENHANCEMENTS

The current project demonstrates how traditional VPN architectures can be modernized using a cloud-native Zero Trust solution while identifying vulnerabilities through security assessment tools. However, several improvements can be implemented in the future to enhance the effectiveness, scalability, and security of the proposed system across all stages.

Stage 1 – Vulnerability Analysis and Security Framework

In the first stage of the project, vulnerabilities were analyzed based on the **OWASP Top 10 categories and CWE references**. As a future enhancement, the vulnerability analysis can be expanded by integrating additional cybersecurity frameworks such as the **NIST Cybersecurity Framework, MITRE ATT&CK, and ISO 27001 security controls**. These frameworks provide a broader perspective on enterprise security and help in identifying advanced attack techniques and mitigation strategies.

Another improvement would be the development of an **automated vulnerability mapping system** that continuously updates vulnerability databases and correlates them with newly discovered threats. This would allow organizations to proactively monitor emerging risks and maintain updated security controls against evolving cyber threats.

Stage 2 – Advanced Vulnerability Scanning and Security Testing

In the second stage, vulnerability assessment was conducted using **Tenable Nessus** to identify security weaknesses in the target system. As a future enhancement, the scanning process can be expanded by integrating additional security testing tools such as **OWASP ZAP, Burp Suite, and OpenVAS** to perform deeper security analysis, including web application testing and API vulnerability detection.

Another potential enhancement is the implementation of **continuous vulnerability monitoring and automated scanning pipelines**. By integrating vulnerability scanners into a DevSecOps environment, organizations can perform regular security assessments and automatically detect new vulnerabilities whenever system configurations or software components change.

Stage 3 – Enhanced Zero Trust Implementation with Zscaler

In the third stage, the project proposed replacing legacy VPN architectures with a **Zscaler-based Zero Trust security model**. Future enhancements could involve integrating **advanced identity verification technologies such as multi-factor authentication (MFA), biometric authentication, and device posture assessment** to further strengthen access control.

Additionally, integrating **AI-driven threat detection and Security Information and Event Management (SIEM) systems** with the Zero Trust architecture can improve real-time monitoring and incident response capabilities. These enhancements would enable organizations to detect suspicious activities quickly and maintain stronger protection against sophisticated cyber threats.

TOPICS EXPLORED :

Legacy VPN architecture, security limitations of traditional VPNs, Zero Trust security model, identity-based access control, cloud-native security architecture, Zscaler Zero Trust platform, attack surface reduction, prevention of lateral movement, OWASP Top 10 vulnerability analysis, CWE vulnerability mapping, vulnerability assessment using Tenable Nessus, TLS and cryptographic vulnerabilities, ICMP information disclosure, service detection and OS fingerprinting, secure remote access using Zero Trust architecture.

TOOLS EXPLORED :

- Whatismyipaddress
- Medium
- Tenable Nessus
- OWASP 2025